ARJAN KHERA

WINLOCAL CYBERSECURITY: PRESENT AND FUTURE

A Security Evaluation Using the NIST CSF 2.0

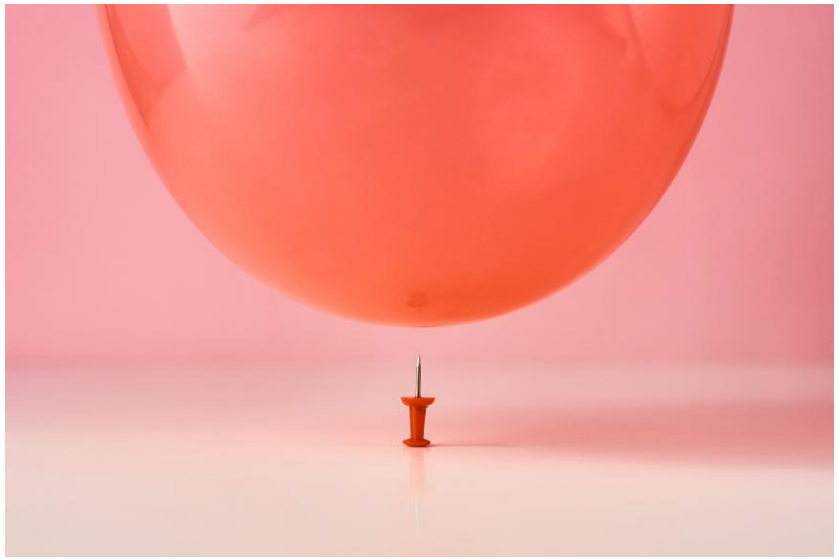




AS IT IS

- Problematic
- Lack of security controls/culture in all areas
- Stands to lose customers, clients and revenue
- Ransomware attack – loss of trust

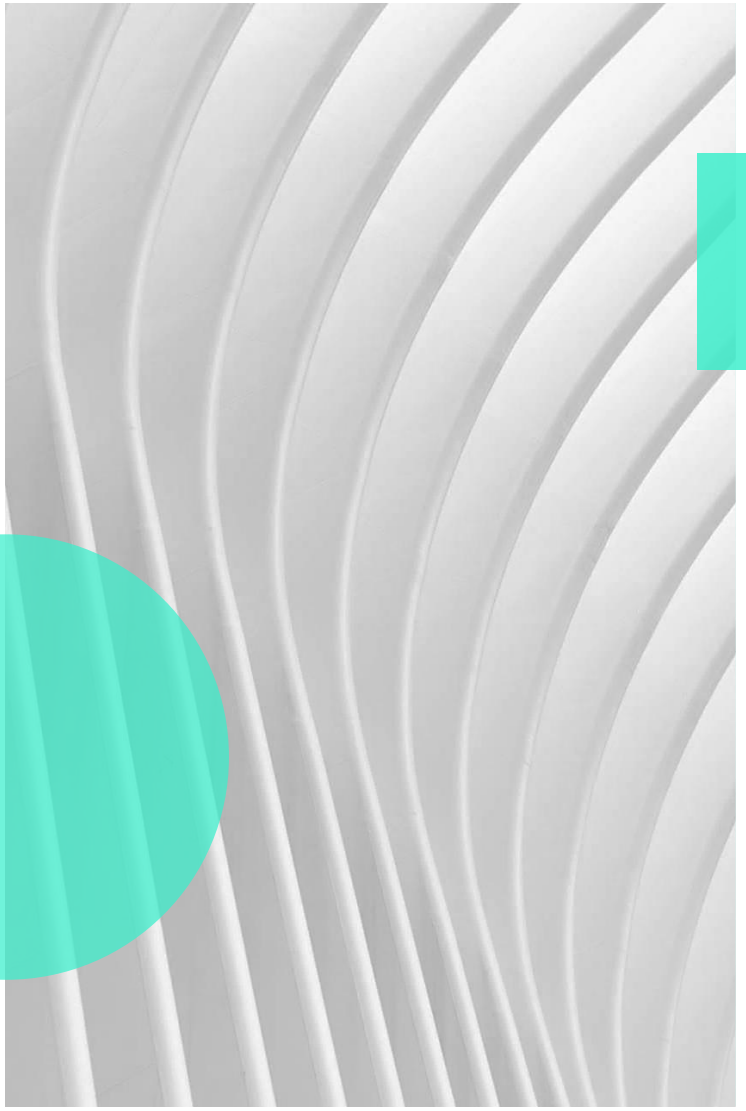
RISKS

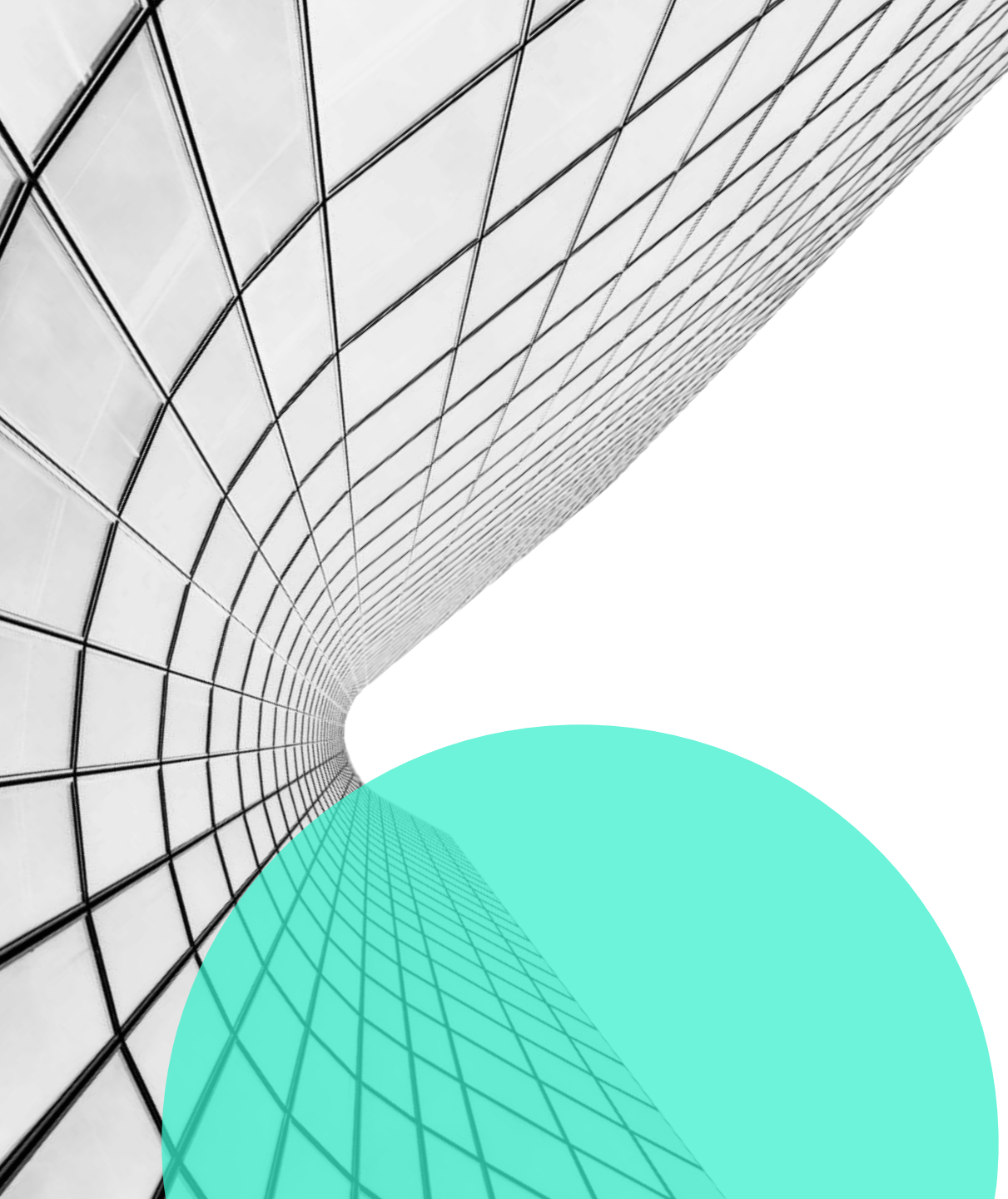


Area	Status	Risk
Network	Flat, Unsegmented	Critical
Hardware/ Infrastructure	Outdated, On-Premises	Critical
Customer Data Handling/ Storage	Unprotected, Exposed	Critical
Access Control Mechanisms	Nonexistent	Critical
Staff Awareness	No Training/ Programs, No Culture	Critical

NIST CSF: GOVERN

- Requires organisation to establish, communicate and monitor risk management strategy.
- WinLocal have failed to develop a risk strategy, clear lack of policy and organisational practices
- No formal staff training - weak password practices and susceptible to phishing
- Need to develop cybersecurity policy, implement risk management process – learn from past and document practices
- Mandatory staff training, enforce strong password policies, MFA





NIST CSF: IDENTIFY

- Understanding the organisation's current cybersecurity risks, current assets and vulnerabilities
- Hardware/infrastructure outdated, potentially vulnerable to threat actors
- Customer data exfiltrated over 10 weeks, no formal identification of assets
- Business should maintain an inventory of assets – hardware, software, systems. Update when necessary
- Consider sensitive data being collected. How is it used? Where is it located?

NIST CSF: PROTECT

- Safeguards used by an organization to manage cybersecurity risks
- Clear failures – Network flat and unsegmented, attackers moved freely among all layers gaining access to sensitive data. Single entry point
- Sensitive data completely unprotected
- No access controls – same problem, single entry point
- Implement least privilege access controls, segment network
- Barriers to protect layers, customer data



TRANSFORM WINLOCAL'S SECURITY POSTURE WITH NIST CSF 2.0

Govern	Identify	Protect
Establish formal policies, train staff, create cybersecurity culture and understanding	Can't protect something you don't know about, formal asset and data inventory/classification ensures proper handling, risks are pre-empted	Safeguards of critical importance, attacks quarantined with controls and barriers, least privilege

THANK YOU